

Criptoagilidade Orientada por CBOM para Migração Pós-Quântica em Ambientes Híbridos Three-Tier Método e Validação Experimental em Topologia Bancária Simulada

Thomaz Klifson Falcão Barboza¹, Reginaldo Arakaki¹

¹Inteli – Instituto de Tecnologia e Liderança
São Paulo, SP – Brasil

thomaz.barboza@sou.inteli.edu.br

reginaldo.arakaki@prof.inteli.edu.br

Abstract. *Este artigo apresenta um roteiro de criptoagilidade para migração criptográfica em ambientes híbridos three-tier sob risco quântico. O método combina inventário CBOM/SBOM, decisão por políticas, canário, observabilidade, rollback e retenção de evidências, alinhado ao NIST e aos padrões FIPS 203–205. A validação usou topologia bancária simulada com oito nós lógicos em Podman rootless. S4-T01 processou 150 requisições sem falhas e p95 de 39,71 ms; S4-T02 processou 40 requisições sem falhas e p95 de 24,70 ms; S4-COMP, com mesma rota e carga, obteve p95 de 42,58 ms no baseline e 27,20 ms no canário. Sob stress, 10.000 requisições terminaram sem falhas HTTP, mas o p95 de 1149,64 ms violou LAT-01. A falha do mock-vault/KMS simulado gerou HTTP 500 e recuperou HTTP 200 após reinício. As evidências sustentam a viabilidade operacional do roteiro, sem comprovar mTLS real, KMS real ou PQC no dataplane.*

Palavras-chave: Criptoagilidade; criptografia pós-quântica; CBOM; SBOM; arquitetura three-tier; NIST; migração criptográfica.

1. Introdução

A evolução da computação quântica amplia o risco associado ao uso prolongado de criptografia de chave pública baseada em fatoração e logaritmo discreto. Além da futura quebra de confidencialidade e autenticidade, organizações precisam considerar ataques do tipo *harvest-now, decrypt-later*, nos quais dados cifrados são coletados hoje para decifração posterior [NCCoE/NIST 2023].

Em ambientes corporativos híbridos, a migração não se reduz à troca de uma biblioteca ou de um algoritmo. Dependências criptográficas estão distribuídas entre terminações TLS, aplicações, APIs, bancos de dados, certificados, segredos, pipelines e componentes legados. Sem inventário confiável, políticas versionadas, observabilidade e mecanismos de reversão, uma alteração pode introduzir incompatibilidade, indisponibilidade ou perda de rastreabilidade.

A lacuna prática investigada neste trabalho é como organizar uma transição incremental em uma arquitetura three-tier híbrida, mantendo evidências para decidir, implantar,

observar e reverter mudanças. A contribuição é um roteiro reproduzível de criptoagilidade orientado por CBOM, associado a um gateway de políticas e validado em uma topologia bancária simulada. O artigo não afirma que algoritmos pós-quânticos foram executados no dataplane; avalia-se a infraestrutura operacional e de governança que antecede essa adoção.

2. Fundamentação

2.1. Risco quântico e padronização

O NIST conduz a transição para criptografia pós-quântica e publicou padrões para encapsulamento de chaves e assinaturas digitais. O FIPS 203 especifica ML-KEM, o FIPS 204 especifica ML-DSA e o FIPS 205 especifica SLH-DSA [NIST 2024a, 2024b, 2024c]. Esses padrões definem primitivas alvo, mas sua adoção corporativa depende de descoberta de usos existentes, compatibilidade, governança de chaves e validação operacional.

2.2. Criptoagilidade, CBOM e SBOM

Criptoagilidade é a capacidade de identificar, substituir e governar mecanismos criptográficos sem redesenhar integralmente o sistema. Um CBOM complementa o SBOM ao registrar algoritmos, protocolos, parâmetros, bibliotecas, certificados e pontos de uso. O IBM CBOM Kit e o suporte a CBOM no ecossistema CycloneDX oferecem bases para inventário estruturado [IBM Research 2022, IBM 2024, OWASP CycloneDX 2024]. Neste trabalho, o CBOM é a entrada do processo de decisão, e sua integridade é verificada antes de qualquer automação.

2.3. Migração incremental e resiliência

Implantações canárias limitam o raio de impacto de mudanças. Políticas, feature flags, SLOs e rollback permitem interromper a expansão quando surgem falhas ou regressões. Para migração criptográfica, esse ciclo deve conservar manifestos antes/depois, decisões, telemetria e registros de recuperação. Perfis híbridos clássico+PQC são uma estratégia de transição, mas sua eficácia e seu overhead precisam ser medidos em um dataplane que realmente execute as primitivas correspondentes.

3. Trabalhos Relacionados

Os guias do NIST tratam da descoberta e da migração de criptografia vulnerável ao risco quântico [NIST 2023–2024]. O IBM CBOM Kit concentra-se no inventário criptográfico e na geração de artefatos para análise [IBM 2024]. O CycloneDX amplia a integração de CBOM a práticas de cadeia de suprimentos de software [OWASP 2024]. Trabalhos sobre Kyber, precursor do ML-KEM, discutem propriedades e desempenho da primitiva [Bos et al. 2018].

Essas contribuições cobrem padronização, inventário ou algoritmo. O diferencial deste trabalho é integrar esses elementos a um fluxo operacional com políticas, canário, observabilidade, rollback e evidências em uma topologia three-tier. A validação permanece deliberadamente limitada ao que os artefatos demonstram: os experimentos avaliam o roteiro e a topologia simulada, não o overhead criptográfico de ML-KEM, ML-DSA, mTLS ou KMS de produção.

4. Metodologia

4.1. Desenho da pesquisa

Foi conduzida pesquisa aplicada e exploratória, com estudo de caso quantitativo em ambiente controlado. As fontes primárias foram os manifestos e protótipos do repositório, os scripts k6, os arquivos de topologia, os logs de execução e o pacote de revalidação de 10 de junho de 2026. A unidade de análise foi o comportamento da cadeia three-tier e de seus controles de governança durante cenários nominais, comparação controlada, stress e falha de dependência.

4.2. Ambiente e instrumentação

O ambiente foi executado em servidor acadêmico Ubuntu 24.04.3 LTS, com 64 vCPU, 125 GiB de RAM e Podman 4.9.3 em modo rootless [Red Hat 2024]. O k6 gerou carga a partir de um nó lógico dedicado. Respostas HTTP, resumos JSON, logs de containers, contadores de eventos e saídas do gateway CBOM foram retidos como evidência. A carga empregou dados sintéticos e a rota funcional `/chain`.

4.3. Cenários e critérios

Os cenários foram organizados em quatro grupos:

- **Nominais:** S4-T01 (baseline), S4-T02 (nó canário) e S4-T03 (cadeia funcional app–segurança–dados–canário).
- **Comparação controlada:** S4-COMP, com baseline e canário na mesma rota, 5 VUs, 30 s e 150 requisições por nó.
- **Stress:** S4-E03, com 50 VUs e 10.000 transações sintéticas.
- **Falha de dependência:** S4-E01, com parada e reinício do `security-integration-node`, que implementa um mock-vault/KMS simulado.

As variáveis principais foram taxa de falha HTTP, número de iterações, latência média, p95, latência máxima, disponibilidade durante a falha e recuperação após reinício. O SLO LAT-01 exige p95 inferior a 150 ms. Considerou-se disponibilidade funcional quando as requisições foram concluídas com sucesso HTTP; recuperação foi caracterizada pelo retorno a HTTP 200 após restauração da dependência.

5. Arquitetura e Roteiro Proposto

5.1. Topologia de oito nós

A topologia representa camadas web, aplicação e dados, acrescidas de controle, segurança, observabilidade e geração de carga. Foram usados oito nós lógicos: `k8s-control` para protótipos CBOM/políticas; `k8s-worker-1` como baseline; `k8s-worker-2` para a cadeia aplicação–segurança–dados; `k8s-worker-3` como canário; `data-node` com PostgreSQL; `security-integration-node` como mock-vault/KMS HTTP; `observability-node` com Prometheus previsto; e `load-chaos-node` para carga e falhas.

5.2. Fluxo de criptoagilidade

O roteiro possui cinco etapas. Em *descobrir*, o CBOM registra dependências criptográficas por serviço. Em *decidir*, o gateway aplica políticas, classifica risco e define um perfil alvo. Em *migrar*, a mudança é implantada em canário, com escopo e reversão definidos. Em *validar*, telemetria e testes verificam disponibilidade, latência e conformidade. Em *consolidar*, as evidências são vinculadas à decisão antes da expansão.

O protótipo de gateway processou um CBOM com três componentes e identificou dois achados de alto risco, duas violações e duas ações de migração. O cenário S4-E04 revelou que um manifesto adulterado poderia reduzir as ações recomendadas; a inclusão de HMAC-SHA256 passou a bloquear o artefato inválido antes da automação. Essa assinatura simétrica é um controle de protótipo, não uma substituição de uma infraestrutura corporativa de assinatura e gestão de chaves.

6. Execução Experimental

S4-T01 e S4-T02 revalidaram os endpoints baseline e canário em cargas nominais distintas. S4-T03 executou uma chamada funcional a partir do nó de aplicação, consultando o mock-vault, gravando no banco e alcançando o nó canário. Embora o identificador histórico S4-T03 tenha sido associado a mTLS no plano experimental, a evidência atual usa `http://security-integration-node:8080/secret`; portanto, o resultado valida apenas o encadeamento funcional.

S4-COMP foi criado para remover a limitação da comparação anterior entre cargas diferentes. Os dois nós receberam a mesma rota, carga, duração e quantidade de requisições. S4-E03 comprimiu 10.000 transações em uma execução com 50 VUs. S4-E01 registrou o estado antes, durante e depois da parada manual do serviço de segurança.

7. Resultados

7.1. Visão consolidada

A Tabela 1 apresenta os seis cenários revalidados solicitados. Os resultados de S4-T05 e S4-E04 foram mantidos como evidências complementares de governança na seção anterior.

Nos cenários nominais, S4-T01 e S4-T02 permaneceram abaixo de LAT-01 e não apresentaram falhas HTTP. Em S4-T03, a resposta registrou `security.secret_profile=mock-vault`, `database.ok=true` e `elapsed_ms=51.17`. Não se pode inferir mTLS real, pois a dependência de segurança foi acessada por HTTP.

7.2. Comparação operacional controlada

O nó canário apresentou menor latência nessa execução controlada. A igualdade de rota, carga, duração e amostra corrige a limitação da comparação nominal entre S4-T01 e S4-T02. Entretanto, não se pode interpretar a diferença como overhead ou ganho de PQC/mTLS, pois os dois nós executam serviços HTTP simulados e não há evidência de primitivas PQC no dataplane.

Tabela 1. Resultados consolidados da revalidação

Cenário	Evidência observada	Status
S4-T01	150 requisições/iterações; 0 falhas; média 30,36 ms; p95 39,71 ms.	Aprovado
S4-T02	40 requisições/iterações; 0 falhas; média 20,43 ms; p95 24,70 ms.	Aprovado
S4-T03	Cadeia app–mock-vault–banco–canário; HTTP 200; 51,17 ms; banco ok=true.	Aprovado funcionalmente
S4-COMP	Mesma rota/carga; 150+150 requisições; 0 falhas; p95 42,58 vs. 27,20 ms.	Aprovado
S4-E03	10.000 requisições; 0 falhas; média 203,47 ms; p95 1149,64 ms.	Disponibilidade aprovada; LAT-01 reprovado
S4-E01	HTTP 200 antes, HTTP 500 durante a falha e HTTP 200 após reinício.	Parcialmente aprovado

Tabela 2. S4-COMP: baseline e canário sob as mesmas condições

Métrica	Baseline	Canário	Variação
VUs / duração	5 / 30 s	5 / 30 s	–
Requisições	150	150	–
Falhas HTTP	0	0	–
Latência média	31,13 ms	19,87 ms	-36,19%
Latência p95	42,58 ms	27,20 ms	-36,12%

7.3. Stress com 10.000 transações

S4-E03 executou 50 VUs e 10.000 requisições sobre `/chain`, sem falhas HTTP. A latência média foi 203,47 ms, o p95 foi 1149,64 ms e a latência máxima foi 6235,52 ms. Assim, a disponibilidade funcional foi aprovada, mas LAT-01 foi reprovado. O resultado não deve ser ocultado nem agregado aos cenários nominais: ele identifica um limite de desempenho da configuração avaliada.

7.4. Falha e recuperação do mock-vault

Em S4-E01, a rota retornou HTTP 200 antes da falha, com 40,09 ms e banco OK; durante a parada do nó de segurança, retornou HTTP 500 e erro DNS; após o reinício, voltou a HTTP 200 em 36,25 ms, com banco OK. O experimento demonstrou detecção da falha e recuperação operacional, mas não tolerância plena: durante a indisponibilidade, a aplicação não manteve resposta bem-sucedida. Também não se trata de KMS real; o serviço retorna um perfil estático de mock-vault.

8. Discussão

Os cenários nominais indicam que a topologia simulada suporta o fluxo web–aplicação–dados com baixa latência e sem falhas nas janelas avaliadas. A comparação S4-COMP fortalece a análise porque controla rota, concorrência, duração e tamanho da amostra.

Ainda assim, o melhor resultado do canário descreve diferença operacional entre nós e não efeito criptográfico.

S4-E03 mostrou que disponibilidade e desempenho devem ser avaliados separadamente. A ausência de falhas HTTP poderia sugerir robustez, mas o p95 superior a um segundo viola o SLO e expõe saturação ou contenção que requer instrumentação adicional. S4-E01 mostrou recuperação simples após reinício, mas a propagação de HTTP 500 revela ausência de cache, fallback ou degradação controlada para a dependência de segurança.

Os registros de runtime classificaram diversos containers como `unhealthy`, e o nó de observabilidade encerrou com erro em uma captura. Mesmo assim, os endpoints funcionais responderam durante os testes. Essa divergência indica healthchecks ou integração com o provider Compose inconsistentes; não deve ser interpretada como saúde operacional plenamente validada. A observabilidade Prometheus/Grafana permanece incompleta.

9. Limitações

O ambiente é uma simulação em um único servidor acadêmico com Podman rootless, não uma implantação corporativa distribuída. O mock-vault/KMS não executa KMS, HSM, rotação ou envelope encryption reais; S4-T03 usa HTTP e não comprova mTLS; os artefatos recomendam perfis pós-quânticos, mas não executam ML-KEM, ML-DSA ou SLH-DSA no dataplane. S4-COMP é uma comparação operacional, S4-E03 violou LAT-01 sob stress e S4-E01 retornou HTTP 500 durante a falha. Healthchecks inconsistentes, observabilidade parcial, execução única dos cenários e ausência de rotação real, certificado expirado, rollback automatizado, custo e telemetria criptográfica limitam generalização e inferência estatística.

10. Ameaças à Validade

Latência HTTP e taxa de sucesso representam comportamento operacional, mas não medem segurança pós-quântica; por isso, nomes históricos associados a TLS híbrido ou KMS foram interpretados apenas conforme protocolo e código observados. As execuções ocorreram em host compartilhado e podem sofrer influência de escalonamento, cache, banco e criação de conexões; sem repetições independentes, randomização e controle de recursos, a diferença de latência em S4-COMP permanece descritiva. Os oito containers lógicos também não reproduzem latências inter-região, balanceadores, HSMs, service mesh ou diversidade de clientes de um banco real.

11. Reprodutibilidade

Os artefatos de revalidação estão organizados em `docs/revalidation/` e no pacote `revalidation-evidence-2026-06-10.tgz`. O diretório contém o sumário consolidado, resumos JSON e saídas do k6, a resposta S4-T03, a comparação S4-COMP, os resultados de stress, as três fases de S4-E01 e capturas de runtime. Os scripts de carga e a topologia estão em `lab/topology/`; o gateway e os manifestos CBOM estão em `code/`. Para reprodução rigorosa, devem ser registrados versões de imagens, estado do host, horário, semente quando aplicável e pelo menos três repetições independentes por cenário.

12. Conclusão

O trabalho entrega um roteiro prático de criptoagilidade que conecta inventário CBOM, políticas, implantação canária, observabilidade, rollback e evidências. A revalidação confirma baseline e canário nominais, adiciona comparação operacional controlada, executa 10.000 transações sob stress e observa falha e recuperação do mock-vault. Os resultados também delimitam o alcance: LAT-01 foi violado sob stress, a aplicação retornou HTTP 500 durante a indisponibilidade de segurança, e mTLS, KMS real e PQC no dataplane não foram comprovados. Como continuidade, propõe-se implantar mTLS real, integrar KMS/HSM, executar primitivas FIPS 203–205, automatizar rollback, corrigir observabilidade e repetir experimentos com análise estatística.

Referências

- Bos, J. et al. (2018). CRYSTALS-Kyber: A CCA-Secure Module-Lattice-Based KEM. In *Proceedings of the IEEE European Symposium on Security and Privacy*.
- IBM (2024). IBM/CBOM GitHub Repository.
- IBM Research (2022). Cryptographic Bill of Materials Speeds Quantum Safe Adoption.
- National Cybersecurity Center of Excellence and National Institute of Standards and Technology (2023). SP 1800-38: Migration to Post-Quantum Cryptography. Technical report, National Institute of Standards and Technology.
- National Institute of Standards and Technology (2024a). FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard. Federal Information Processing Standards Publication 203, National Institute of Standards and Technology.
- National Institute of Standards and Technology (2024b). FIPS 204: Module-Lattice-Based Digital Signature Standard. Federal Information Processing Standards Publication 204, National Institute of Standards and Technology.
- National Institute of Standards and Technology (2024c). FIPS 205: Stateless Hash-Based Digital Signature Standard. Federal Information Processing Standards Publication 205, National Institute of Standards and Technology.
- National Institute of Standards and Technology (2024d). Post-Quantum Cryptography Project.
- OWASP CycloneDX (2024). CycloneDX v1.6 Released (including CBOM).
- Red Hat (2024). Podman: A Daemonless Container Engine.